

Ethical Hacker

PART 4

Vulnerability Scanning

Assistant Teacher: Mubarak Altamimi.

Fall in love with the process, and the results will come.
~ Eric Thomas



What is Vulnerability?

- ❑ Refers to the existence of **weakness** in an asset that can be exploited by threat agents



Common Reasons behind the Existence of Vulnerability

- 1 Hardware or software misconfiguration
- 2 Insecure or poor design of the network and application
- 3 Inherent technology weaknesses
- 4 Careless approach of end users

Examples of Vulnerabilities

Technological Vulnerabilities	Description
TCP/IP protocol vulnerabilities	HTTP, FTP, ICMP, SNMP, SMTP are <u>inherently</u> insecure
Operating System vulnerabilities	An OS can be vulnerable because: - It is inherently insecure - It is not <u>patched with the latest updates</u>
Network Device Vulnerabilities	Various network devices such as routers, firewall, and switches can be vulnerable due to: - Lack of password protection - Lack of authentication - Insecure routing protocols - Firewall vulnerabilities ?

Configuration Vulnerabilities	Description
User account vulnerabilities	Originating from the insecure transmission of user account details such as usernames and passwords, over the network
System account vulnerabilities	Originating from setting of weak passwords for system accounts
Internet service misconfiguration	Misconfiguring internet services can pose serious security risks. For example, enabling JavaScript and misconfiguring IIS, Apache, FTP, and Terminal services, can create security vulnerabilities in the network
Default password and settings	Leaving the network devices/products with their default passwords and settings
Network device misconfiguration	Misconfiguring the network device

Vulnerability Research

- The process of analyzing protocols, services, and configurations to **discover vulnerabilities and design flaws** that will expose an operating system and its applications to exploit, attack, or misuse
- Vulnerabilities are classified based on **severity level** (low, medium, or high) and **exploit range** (local or remote)

An administrator needs vulnerability research: to

1 To gather information concerning **security trends, threats, attack surfaces**, attack vectors and techniques

2 To discover **weaknesses** in the OS and applications, and alert the network administrator before a **network attack**

3 To **gather information** to aid in the prevention of security issues

4 To know **how to recover** from a network attack

Resources for Vulnerability Research

Microsoft MSRC | Security Updates | Acknowledgements | Developer

MSRC > Customer Guidance > Security Update Guide

Welcome to the new and improved Security Update Guide! We'd love your feedback. Please click here to share your thoughts or email us at msrc_eng_support@microsoft.com. Thank you!

Microsoft Security Response Center (MSRC)

The Microsoft Security Response Center (MSRC) investigates all reports of security vulnerabilities affecting Microsoft products and services, and provides the information here as part of the ongoing effort to help you manage security risks and help keep your systems protected.

All Deployments Vulnerabilities

Feb 9, 2022 - Mar 28, 2022

Edit columns Download Filters

Keyword Product Family Severity Impact Platform Release notes Clear

Release ...	Product	Platform	Impact	Severity	Article	Download
Mar 8, 2022	Raw Image Extension	Windows 10 Version 1607 for x64-based Systems	Remote Code Execution	Important	Update Information	Security Bulletin
Mar 8, 2022	Raw Image Extension	Windows 10 Version 1607 for 32-bit Systems	Remote Code Execution	Important	Update Information	Security Bulletin
Mar 8, 2022	Raw Image Extension	Windows 10 for x64-based Systems	Remote Code Execution	Important	Update Information	Security Bulletin
Mar 8, 2022	Raw Image Extension	Windows 10 for 32-bit Systems	Remote Code Execution	Important	Update Information	Security Bulletin

<https://msrc.microsoft.com>



Packet Storm

<https://packetstormsecurity.com>



Dark Reading

<https://www.darkreading.com>



Trend Micro

<https://www.trendmicro.com>



Security Magazine

<https://www.securitymagazine.com>



PenTest Magazine

<https://pentestmag.com>

What is Vulnerability Assessment?

- Vulnerability assessment is an in-depth **examination of the ability of a system or application**, including current security procedures and controls, to withstand the exploitation
- It recognizes, measures, and classifies security vulnerabilities in a **computer system, network, and communication channels**

A vulnerability assessment may be used to:

- Identify weaknesses that could be exploited
- Predict the effectiveness of additional security measures in protecting information resources from attacks



Information obtained from the vulnerability scanner includes:

- Network vulnerabilities
- Open ports and running services
- Application and services vulnerabilities
- Application and services configuration errors

Vulnerability Scoring Systems and Databases

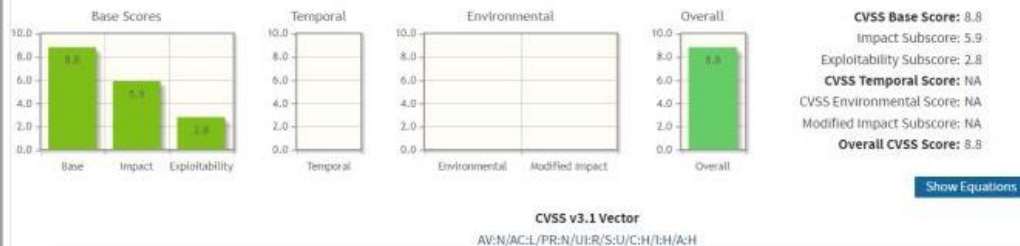


Common Vulnerability Scoring System (CVSS)

Common Vulnerability Scoring System Calculator CVE-2022-22620

Source: NIST

This page shows the components of the CVSS score for example and allows you to refine the CVSS base score. Please read the CVSS standards guide to fully understand how to score CVSS vulnerabilities and to interpret CVSS scores. The scores are computed in sequence such that the Base Score is used to calculate the Temporal Score and the Temporal Score is used to calculate the Environmental Score.



Base Score Metrics

Exploitability Metrics

Attack Vector (AV)*

Network (AV:N) Adjacent Network (AV:A) Local (AV:L) Physical (AV:P)

Attack Complexity (AC)*

Low (AC:L) High (AC:H)

Privileges Required (PR)*

None (PR:N) Low (PR:L) High (PR:H)

User Interaction (UI)*

None (UI:N) Required (UI:R)

Scope (S)*

Unchanged (S:U) Changed (S:C)

Impact Metrics

Confidentiality Impact (C)*

None (C:N) Low (C:L) High (C:H)

Integrity Impact (I)*

None (I:N) Low (I:L) High (I:H)

Availability Impact (A)*

None (A:N) Low (A:L) High (A:H)

* - All base metrics are required to generate a base score.

<https://www.first.org/cvss/specification-document>

<https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>

Common Vulnerabilities and Exposures (CVE)



CVE List +

CNAs +

About +

WGs +

News & Blog +

Board +



Search CVE List

Downloads

Data Feeds
IDs

Update a CVE Record

Request CVE

TOTAL CVE Records: 172594

NOTICE: Transition to the all-new CVE website at [WWW.CVE.ORG](https://www.cve.org) is underway and will last up to one year. (details)

NOTICE: Changes coming to CVE Record Format JSON and CVE List Content Downloads in 2022.

HOME > CVE > SEARCH RESULTS

Search Results

There are 6255 CVE Records that match your search.

Name	Description
CVE-2022-27950	In drivers/hid/hid-elo.c in the Linux kernel before 5.16.11, a memory leak exists for a certain hid_parse
CVE-2022-27666	A heap buffer overflow flaw was found in IPsec ESP transformation code in net/ipv4/esp4.c and net/ipv6
CVE-2022-27223	In drivers/usb/gadget/udc/udc-xilinx.c in the Linux kernel before 5.16.12, the endpoint index is not valid
CVE-2022-26966	An issue was discovered in the Linux kernel before 5.16.12. drivers/net/usb/sr9700.c allows attackers to
CVE-2022-26978	drivers/bluetooth/virtio_bt.c in the Linux kernel before 5.16.3 has a memory leak (socket buffers have n
CVE-2022-26490	st21nfca_connectivity_event_received in drivers/nfc/st21nfca/se.c in the Linux kernel through 5.16.12 h
CVE-2022-25636	because of untrusted length parameters.
	net/netfilter/nf_dup_netdev.c in the Linux kernel 5.4 through 5.6.10 allows local users to gain privileges
	This is related to nf_tables_offload.

Base Matrix:- exploitability, Impact of(conf. , integrity, availability) <https://nvd.nist.gov>

Temporal Matrix:- Is there: exactly Explo. , solving, trusting.

Environmental matrix:- range impact of system, Environ.

<https://www.cve.org>

Vulnerability Scoring Systems and Databases (Cont'd)

<https://cwe.mitre.org/find/index.html>



National Vulnerability Database (NVD)

NIST
Information Technology Laboratory
NATIONAL VULNERABILITY DATABASE

NVD

VULNERABILITIES

CVE-2022-22652 Detail

Current Description

The GSMA authentication panel could be presented on the lock screen. The issue was resolved by requiring device unlock to interact with the GSMA authentication panel. This issue is fixed in iOS 15.4 and iPadOS 15.4. A person with physical access may be able to view and modify the carrier account information and settings from the lock screen.

[View Analysis Description](#)

Severity CVSS Version 3.x CVSS Version 2.0

CVSS 3.x Severity and Metrics:

NIST: NVD **Base Score:** 6.1 MEDIUM

Vector: CVSS:3.1/AV:P/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

QUICK INFO
CVE Dictionary Entry: CVE-2022-22652
NVD Published Date: 03/18/2022
NVD Last Modified: 03/26/2022
Source: Apple Inc.

<https://nvd.nist.gov>

Common Weakness Enumeration (CWE)

Common Weakness Enumeration
A Community-Developed List of Software & Hardware Weakness Types

2021 HW 25

Home > Search the Site ID Lookup:

Home | About | CWE List | Scoring | Mapping Guidance | Community | News | Search

Search the CWE Web Site

Search

To search the CWE Web site, enter a keyword by typing in a specific term or multiple keywords separated by a space, and click the Google Search button or press return.

About 55 results (0.15 seconds)

CWE-284: Improper Access Control (4.6) - CWE
[cwe.mitre.org > CWE List](#)
Common Weakness Enumeration (CWE) is a list of software weaknesses.

CWE-200: Exposure of Sensitive Information to an ... - CWE
[cwe.mitre.org > CWE List](#)
Common Weakness Enumeration (CWE) is a list of software weaknesses.

CWE-295: Improper Certificate Validation (4.6) - CWE
[cwe.mitre.org > CWE List](#)
The software does not validate, or incorrectly validates, a certificate. + Extended Description. When a certificate is invalid or malicious, it might allow ...

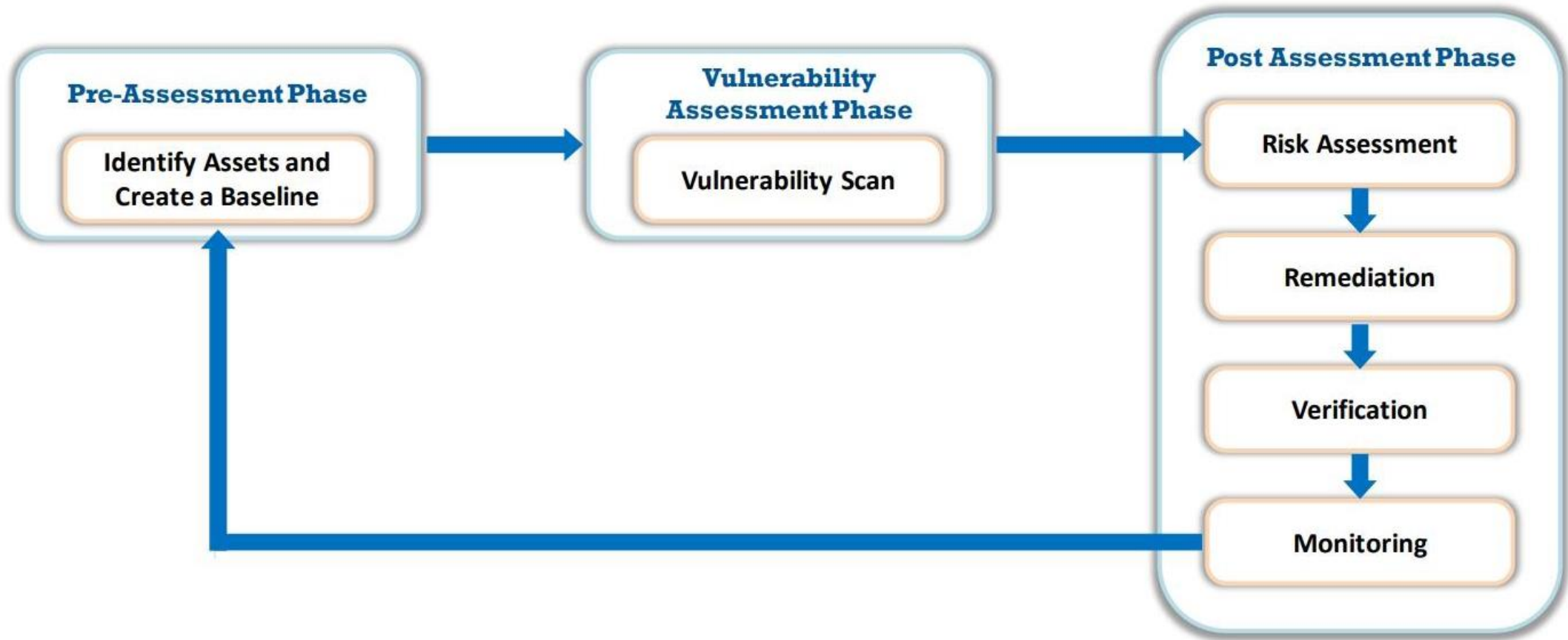
CWE-427: Uncontrolled Search Path Element (4.6) - CWE
[cwe.mitre.org > CWE List](#)
the directory from which the program has been loaded; the current working directory. In some cases, the attack can be conducted remotely, such as when SMB or ...

CWE-552: Files or Directories Accessible to External Parties (4.6)
[cwe.mitre.org > CWE List](#)
This table shows the weaknesses and high level categories that are related to this weakness. These relationships are defined as ChildOf, ParentOf, MemberOf and ...

CWE-313: Cleartext Storage in a File or on Disk (4.6) - CWE
[cwe.mitre.org > CWE List](#)
Common Weakness Enumeration (CWE) is a list of software weaknesses.

<https://cwe.mitre.org>

Vulnerability-Management Life Cycle



Pre-Assessment Phase

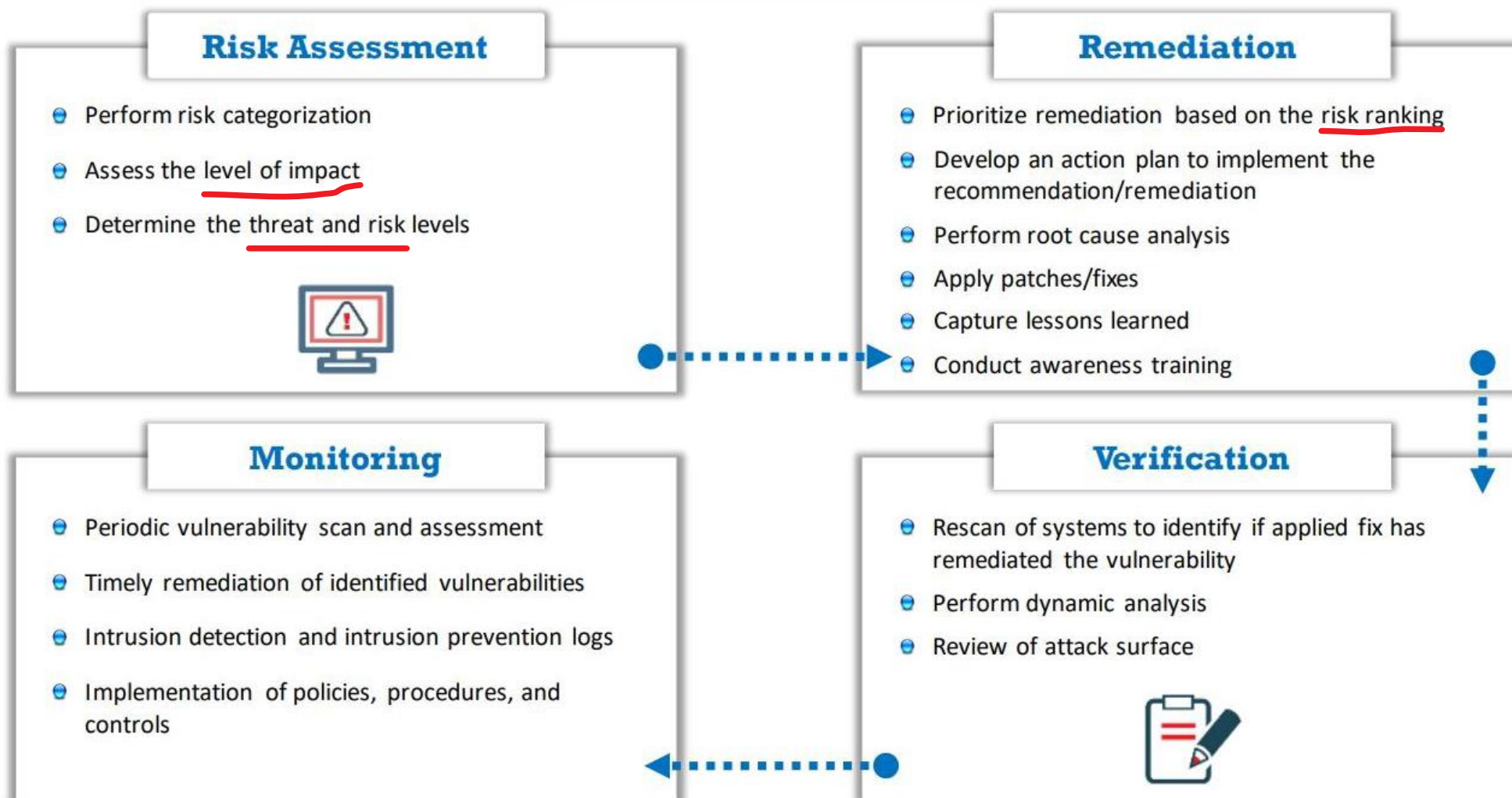
Identify Assets and Create a Baseline

- 1 Identify and **understand** business processes
- 2 Identify the **applications**, **data**, and **services** that support the business processes and perform code reviews
- 3 Identify **approved software**, drivers, and the **basic configuration** of each system
- 4 Create an **inventory** of all assets, and **prioritize/rank** critical assets
- 5 Understand the **network architecture** and **map** the **network infrastructure**
- 6 Identify the **controls** already in place IPS, IDS, Firewall, NAT
- 7 Understand **policy** implementation and **standards** compliance
- 8 Define the **scope** of the assessment
- 9 Create **information protection procedures** to support effective planning, scheduling, coordination, and logistics

Vulnerability Assessment Phase

- 1 Examine and evaluate the **physical security** 
- 2 Check for **misconfigurations** and human errors 
- 3 Run vulnerability scans 
- 4 Select type of scan based on the organization or **compliance requirements** 
- 5 Identify and **prioritize** vulnerabilities 
- 6 Identify **false positives** and **false negatives** 
- 7 Apply business and technology **context** to scanner results 
- 8 Perform OSINT information gathering to **validate** the vulnerabilities 
- 9 Create a vulnerability scan **report** 

Post Assessment Phase



LO#02: Explain Vulnerability Classification and Assessment Types

Vulnerability Classification

Vulnerability Type	Description	Examples
Misconfigurations/Weak Configurations	- Misconfiguration is the most common vulnerability and is mainly caused by human error - It allows attackers to break into a network and gain unauthorized access to systems	Network Misconfigurations Insecure protocols, open ports and services, errors, and weak encryption
		Host Misconfigurations Open permissions and unsecured root accounts
Application Flaws	- Application flaws are vulnerabilities in applications that are exploited by attackers - Flawed applications pose security threats such as data tampering and unauthorized access to configuration stores	Buffer overflows, memory leaks, resource exhaustion, integer overflows, null pointer/object dereference, DLL injection, race conditions, improper input handling, and improper error handling
Poor Patch Management	- Software vendors provide patches that prevent exploitations and reduce the probability of threats exploiting a specific vulnerability - Unpatched software can make an application, server, or device vulnerable to various attacks	Unpatched servers, unpatched firmware, unpatched OS, and unpatched applications
Design Flaws	Logical flaws in the functionality of the system are exploited by the attackers to bypass the detection mechanism and acquire access to a secure system	Incorrect encryption and poor validation of data
Third-Party Risks	Third-party services can have access to privileged systems and applications, through which financial information, customer and employee data, and processes in the enterprise's supply chain can be compromised	Vendor management, supply-chain risks, outsourced code development, data storage, and cloud-based vs. on-premises risks

Vulnerability Classification (Cont'd)

Vulnerability Type	Description
Default Installations/Default Configurations	Failing to change the default settings while deploying software or hardware allows the attacker to guess the settings to break into the system
Operating System Flaws	Owing to OS vulnerabilities, applications such as Trojans, worms, and viruses pose threats
Default Passwords	- Manufacturers provide users with default passwords to access the device during its initial set-up, which users must change for future use - When users forget to update the passwords and continue using the default passwords, they make devices and systems vulnerable to various attacks, such as brute-force and dictionary attacks
Zero-Day Vulnerabilities	- These are unknown vulnerabilities in software/hardware that are exposed but not yet patched - These vulnerabilities are exploited by the attackers before being acknowledged and patched by the software developers or security analysts
Legacy Platform Vulnerabilities	- Legacy platform vulnerabilities are caused by obsolete or familiar code - Legacy platforms are usually not supported when patching technical assets such as smartphones, computers, IoT devices, OSES, applications, databases, firewalls, IDSes, or other network components - This type of vulnerabilities can cause costly data breaches for organizations
<u>System Sprawl/Undocumented Assets</u>	- The system sprawl vulnerability arises within an organizational network because of an increased number of system or server connections without proper documentation or an understanding of their maintenance - These assets are often neglected over time, making them susceptible to attacks
Improper Certificate and Key Management	- Improper certificate and key management may lead to many vulnerabilities that allow attackers to perform password cracking and data exfiltration attacks - Storing or retaining legacy or outdated keys also poses major threats to organizations

Types of Vulnerability Assessment

Assessment Type	Description
Active Assessment	Uses a network scanner to find hosts, services, and vulnerabilities
Passive Assessment	Used to sniff the network traffic to discover present active systems, network services, applications, and vulnerabilities present
External Assessment	Assesses the network from a hacker's perspective to discover exploits and vulnerabilities that are accessible to the outside world
Internal Assessment	Scans the internal infrastructure to discover exploits and vulnerabilities
Host-based Assessment	Conducts a configuration-level check to identify system configurations, <u>user directories, file systems, registry settings, etc.</u> , to <u>evaluate the possibility of compromise</u>
Network-based Assessment	Determines possible network security attacks that may occur on the organization's system
Application Assessment	Tests and analyzes all elements of the web infrastructure for any misconfiguration, outdated content, or known vulnerabilities

Assessment Type	Description
Database Assessment	Focuses on testing databases, such as MYSQL, MSSQL, ORACLE, POSTGRESQL , etc., for the presence of data exposure or injection type vulnerabilities
Wireless Network Assessment	Determines the vulnerabilities in the organization's wireless networks
Distributed Assessment	Assesses the distributed organization assets , such as client and server applications, simultaneously through appropriate synchronization techniques
Credentialed Assessment	Assesses the network by obtaining the credentials of all machines present in the network
Non-Credentialed Assessment	Assesses the network without acquiring any credentials of the assets present in the enterprise network
Manual Assessment	In this type of assessment, the ethical hacker manually assesses the vulnerabilities, vulnerability ranking, vulnerability score , etc.
Automated Assessment	In this type of assessment, the ethical hacker employs various vulnerability assessment tools , such as Nessus, Qualys, GFI LanGuard , etc.

LO#03: Use Vulnerability Assessment Tools

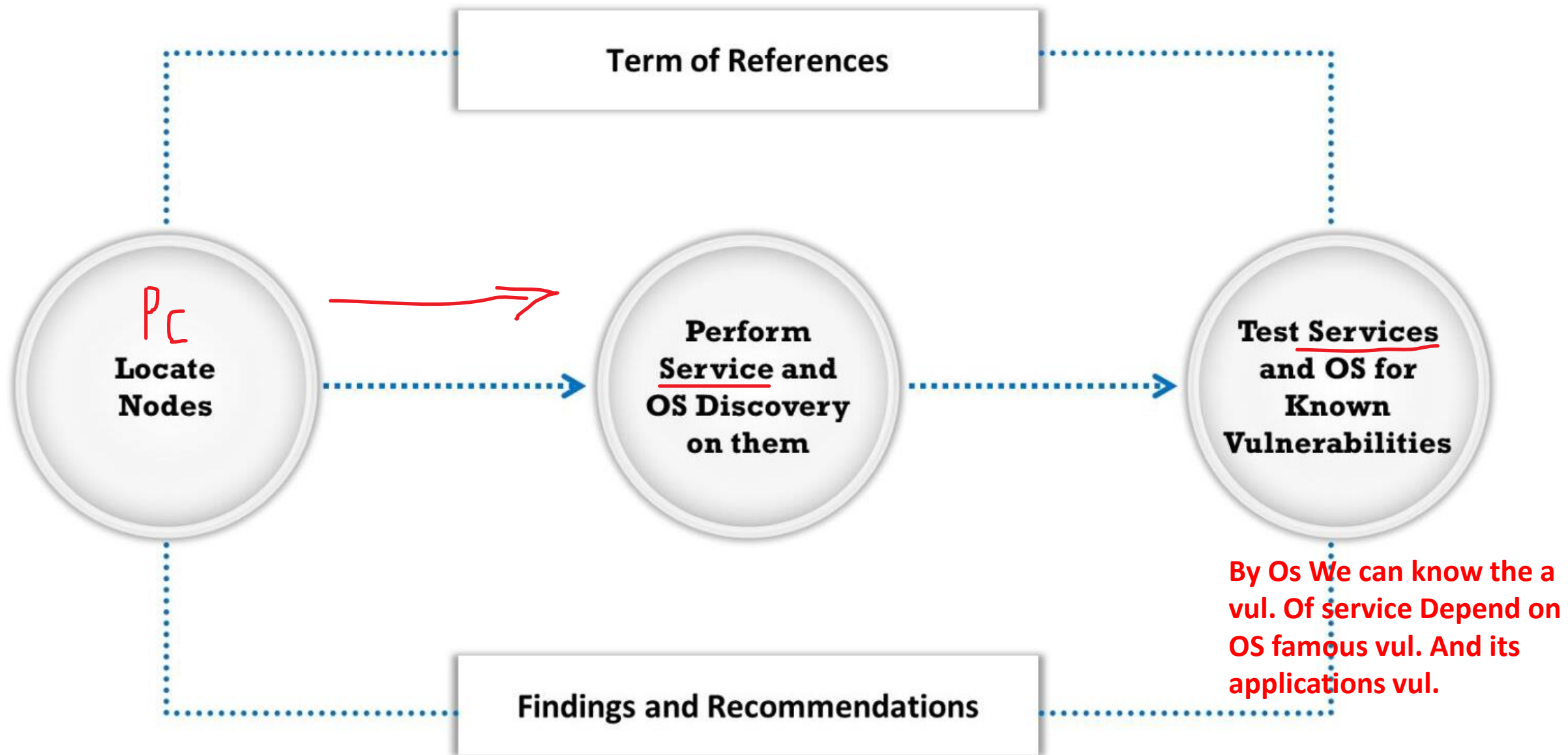


Figure 5.6: The working of vulnerability scanning solutions

Vulnerability Assessment Tools: Qualys Vulnerability Management

■ A cloud-based service that offers immediate global visibility into IT system areas that might be **vulnerable to the latest Internet threats** and how to protect them

■ Aids in the continuous **identification of threats and monitoring of unexpected changes** in a network before they become breaches



<https://www.qualys.com/community-edition/confirm/>

Vulnerability Scorecard Report

December 25

Vulnerability Scorecard Report_system_PO_displayedAll

Source Business Unit

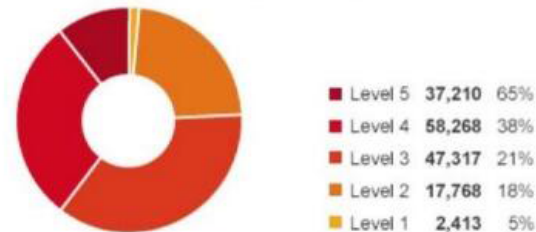
Operating System All

Print

Download

Results

Vulnerability Distribution by Severity Level



Vulnerability Distribution by Type



Asset Groups		Severities by Levels					Vulnerability Type			Hosts w/Vuln Levels 5,4,3		Vulnerability Status				Vulnerability Age by Days		
Title	Hosts	Level 5	Level 4	Level 3	Level 2	Level 1	Confirmed	Potential	IG	Total	%	New	Active	Fixed	ReOpen	> 30	> 60	> 90
The subnet	73	1783	1880	1783	1783	1783	7986	777	777	112	89%	80	80	80	80	0	0	8763
RSA Demo	28	1125	1282	1125	1125	1125	5289	203	203	62	100%	80	80	80	80	0	0	5494
Windows Systems	10	844	92	844	844	844	3076	56	56	28	100%	80	80	80	80	0	0	3132
AIX 586 (Chiharu)	1	0	0	0	0	0	257	15	15	12	100%	80	80	80	80	0	0	6
Empty	1	0	0	0	0	0	11	2	2	1	0	80	80	80	80	0	0	13

<https://www.qualys.com>

Vulnerability Assessment Tools: Nessus Professional and GFI LanGuard



Nessus Professional

An assessment solution for **identifying the vulnerabilities, configuration issues, and malware**

GFI LanGuard

Scans, detects, assesses, and rectifies **security vulnerabilities** in a network and connected devices

Sev	Score	Name	Family	Count
HIGH	7.5	SSL Medium ...	General	2
MEDIUM	6.5	SSL Certificat...	General	2
MEDIUM	6.4 *	SSL Self-Sign...	General	1
MEDIUM	5.3	SSL Certificat...	General	1
INFO		SSL Certificat...	General	2
INFO		SSL Cipher Bl...	General	2
INFO		SSL Cipher S...	General	2
INFO		SSL Perfect F...	General	2
INFO		SSL Certificat...	General	1

<https://www.tenable.com>

SERVER2019 (10.10.1.19)

Vulnerability Level: [Gauge Chart]

Top 5 Issues to Address:

- AutoRun is enabled
- No supported antivirus product found on this machine!
- No supported antivirus product found on this machine!
- OVAL-22538: A router or firewall allows source routed packets from arbitrary hosts (CVE-1999-0510)

Security Sensors:

- Software Updates
- Service Packs and Update Rollups
- Vulnerabilities
- Malware Protection Issue
- Firewall Issues
- Unauthorized Applications
- Audit Status

Computer Details:

- Name: SERVER2019
- IP Address: 10.10.1.19
- MAC Address: 02-15-5D-19-25-0F

Scan Activity:

Agent Status: Agent Not Installed

Results Statistics:

- Other Vulnerabilities: 20 (5 Critical/High)
- Potential Vulnerabilities: 61
- Installed Applications: 35 (0 unauthorized)
- Open Ports: 7
- Queries: 4

Vulnerability Trend Over Time:

<https://www.gfi.com>

Vulnerability Assessment Tools: OpenVAS and Nikto

OpenVAS

A framework of several services and tools offering a comprehensive and powerful **vulnerability scanning** and **vulnerability management solution**

The screenshot shows the OpenVAS web interface in a Mozilla Firefox browser. The page title is "Greenbone Security Assistant - Report Details". The URL is <https://127.0.0.1:9392/report/305f3f60-3419-4e1e-abae-fd7e4935c97c>. The interface includes a navigation bar with tabs like Dashboards, Scans, Assets, Resilience, SecInfo, Configuration, Administration, and Help. Below the navigation bar, there's a section for "RepoThu, Mar 31, 2022 4:03 AM UTC" and a table of results. The table has columns for Vulnerability, Severity, QoD, Host IP, Name, Location, and Created. The results table shows four vulnerabilities:

Vulnerability	Severity	QoD	Host IP	Name	Location	Created
Report outdated / end-of-life Scan Engine / Environment (local)	10.0 (High)	97 %	10.10.1.22		general/tcp	Thu, Mar 31, 2022 4:04 AM UTC
DCE/RPC and MSRPC Services Enumeration Reporting	5.0 (Medium)	80 %	10.10.1.22		135/tcp	Thu, Mar 31, 2022 4:13 AM UTC
SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	2.5 (Medium)	98 %	10.10.1.22		3389/tcp	Thu, Mar 31, 2022 4:12 AM UTC
TCP timestamps	2.6 (Low)	80 %	10.10.1.22		general/tcp	Thu, Mar 31, 2022 4:04 AM UTC

At the bottom, there's a footer with the URL <https://www.openvas.org> and copyright information: "Greenbone Security Assistant (GSA) Copyright (C) 2009-2021 by Greenbone Networks GmbH, www.greenbone.net".

Nikto

A **web server assessment tool** that examines a web server to discover potential problems and security vulnerabilities

The screenshot shows a terminal window with the command `nikto -h www.certifiedhacker.com -Tuning x` being executed. The output displays various findings from the scan, including target information, server details, and several security issues. A red arrow points to the command line. The findings include:

- Target IP: 162.241.216.11
- Target Hostname: www.certifiedhacker.com
- Target Port: 80
- Start Time: 2022-03-31 07:32:51 (GMT-4)
- Server: nginx/1.19.10
- The anti-clickjacking X-Frame-Options header is not present.
- The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS
- Uncommon header 'x-proxy-cache' found, with contents: HIT
- Uncommon header 'x-server-cache' found, with contents: true
- Uncommon header 'host-header' found, with contents: c2hhcmVklmJsdWVob3N0LmNvbQ==
- The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
- Server banner has changed from 'nginx/1.19.10' to 'Apache' which may suggest a WAF, load balancer or proxy is in place
- /certifiedhacker.zip: Potentially interesting archive/cert file found.
- Allowed HTTP Methods: OPTIONS, HEAD, GET, POST
- /webmail/blank.html: IlohaMail 0.8.10 contains an XSS vulnerability. Previous versions contain other non-descript vulnerabilities.
- /securecontrolpanel/: Web Server Control Panel
- /webmail/: Web based mail package installed.
- OSVDB-3233: /mailman/listinfo: Mailman was found on the server.
- OSVDB-2117: /cpanel/: Web-based control panel
- OSVDB-3268: /css/: Directory indexing found.

The terminal window also shows the URL <https://cirt.net> at the bottom right.

Other Vulnerability Assessment Tools



Qualys FreeScan

<https://www.qualys.com>



Acunetix Web Vulnerability Scanner

<https://www.acunetix.com>



Nexpose

<https://www.rapid7.com>



Network Security Scanner

<https://www.beyondtrust.com>



SAINT

<https://www.carson-saint.com>



beSECURE (AVDS)

<https://www.beyondsecurity.com>



Core Impact Pro

<https://www.coresecurity.com>



**N-Stalker Web Application
Security Scanner**

<https://www.nstalker.com>



**ManageEngine Vulnerability
Manager Plus**

<https://www.manageengine.com>



Nipper Studio

<https://www.titania.com>

LO#04: Analyze Vulnerability Assessment Reports

Vulnerability Assessment Reports

1

The vulnerability assessment report **discloses the risks detected after scanning** a network



2

The report **alerts the organization** of possible attacks and suggests **countermeasures**



3

Information available in the reports is used to fix **security flaws**



Vulnerability Assessment Report

Executive Summary

Assessment Overview

Findings

Risk Assessment

Recommendations

Components of a Vulnerability Assessment Report

Executive Summary

- Assessment scope and objectives
- Testing narrative *List*
- Findings summary
- Remediation summary

Assessment Overview

- Assessment methodology
- Scan information
- Target information

Findings

- Scanned hosts
- Types of vulnerabilities identified
- Detailed information on identified vulnerabilities
- Notes describing additional details of scan results

Risk Assessment

- Classification of vulnerabilities based on the risk level
- Potential vulnerabilities that can compromise the system or application
- Critical hosts with severe vulnerabilities

Recommendations

- Prioritization of remediation based on the risk ranking
- Action plan to implement the recommendations for each identified vulnerability
- Root-cause analysis
- Application of patches/fixes
- Lessons learned
- Awareness training
- Implementation of periodic vulnerability assessment
- Implementation of policies, procedures, and controls

Thank you for attendance